

Relatório de Auditoria de Segurança — Inova Gastro 360

Data: 2026-09-01

Escopo: monorepo TypeScript (api-gateway, integrations, messaging-bus, realtime-hub, web Next.js, packages/auth|database|runtime-node), Docker Compose VPS, CI GitHub Actions, exemplos de env.

Método: revisão estática do código atual (sem especulação).

Nota metodológica — mapeamento das categorias à stack

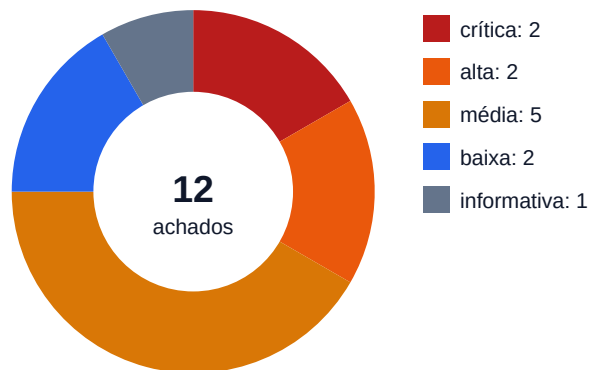
Stack detectada: TypeScript monorepo (npm workspaces + Turbo); backend Workers/Node fetch routers; PostgreSQL 16 + Prisma + **RLS** (app.current_tenant_id / withTenant); auth JWT HS256 (requireAuth/requireRole + cookies HttpOnly); frontend Next.js 15 (App Router, export estático); deploy Docker Compose em VPS Hetzner + Wrangler; CI em .github/workflows.

- 1) **Banco sem tranca** → RLS Postgres + filtros manuais tenant_id/user.tid + role inova_gastro_app. Não é Supabase RLS.
- 2) **Permissão no navegador** → cruzar UI Next com requireRole no api-gateway.
- 3) **IDOR** → todos os handlers em apps/workers/*/src com ID em path/query/body.
- 4) **Chaves** → source, examples, compose, CI, scripts; defaults CHANGE_ME*; histórico git.
- 5) **XSS** → React/Next (dangerouslySetInnerHTML, href/src) + templates backend.

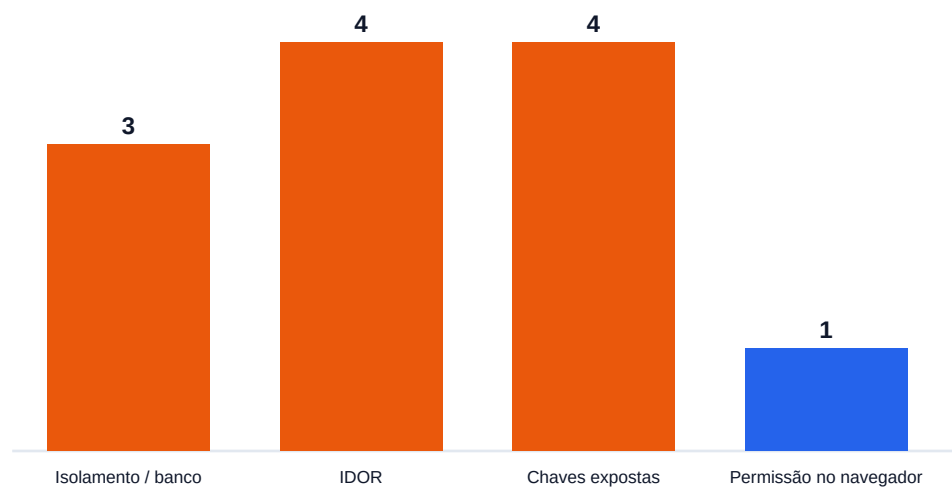
1. Resumo executivo

Foram identificados **12 achados** verificados no código: 2 críticos, 2 altos, 5 médios, 2 baixos, 1 informativos. O isolamento multitenant por RLS + JWT está majoritariamente presente; os riscos centrais concentram-se em **webhooks/fail-open de segredos internos** e em lacunas de amarração branch↔tenant no realtime.

Distribuição por severidade



Distribuição por categoria



2. Pontos fortes

● RLS PostgreSQL + role inova_gastro_app

Migrations ENABLE ROW LEVEL SECURITY por tenant; getSql em produção rejeita owner inova_gastro (assertAppDbRoleDoesNotBypassRLs, db.ts:41-47).

● RBAC no servidor

admin-tenants (super_admin), settings/billing/finance/lcpd mutate com requireRole; catálogo admin com assertCatalogBranchAccess.

● Orders / print-jobs com escopo de filial

assertBranchOpsAccess (UUID + role ops + branches JWT) em list/get/status/print-jobs.

● Realtime broadcast autenticado

POST /broadcast exige INTERNAL_SHARED_SECRET ≥16; WS exige JWT (cookie ou Sec-WebSocket-Protocol) — sem token na query.

● Presign desabilitado + imageUrl allowlist

POST .../image/presign → 410; multipart com magic bytes; isAllowedStoredProductImageUrl scoped a tenant/branch/product.

● XSS frontend

Sem dangerouslySetInnerHTML/innerHTML/eval; productDisplayImage rejeita javascript::; React escapa texto.

● Pagamentos rejeitam placeholders

payments-config PLACEHOLDER rejeita CHANGE_ME/your-/sk_test_CHANGE_ME para Asaas/MP/Stripe.

● Histórico git

Sem .env / .env.production / .dev.vars reais no histórico; apenas examples e NEXT_PUBLIC_* de desenvolvimento.

3. Pontos fracos (riscos centrais)

- Webhooks Asaas/MP e messaging-bus **fail-open** quando o secret está ausente.
- Realtime WS autentica JWT mas **não valida tenant da filial**.
- Placeholders longos de JWT/INTERNAL passam na validação de startup.
- UI não esconde superfícies admin por papel (API segura; UX/LGPD export fracos).
- Tokens ainda no localStorage (superfície XSS residual).

4. Achados detalhados

Sev.	Local	Descrição
CRÍTICA	apps/workers/integrations/src/webhooks/asaas.ts:169-174 e :89-120	F01 — Webhook Asaas sem token obrigatório + assinatura de assinatura confia no body Se ASAAS_WEBHOOK_TOKEN estiver ausente, a verificação é pulada. Eventos SUBSCRIPTION_* mapeiam tenantId/status a partir do JSON do atacante e chamam apply-subscription sem revalidar na API Asaas.
CRÍTICA	apps/workers/messaging-bus/src/index.ts:14-16 e :74-82	F02 — messaging-bus libera /internal/publish sem INTERNAL_SHARED_SECRET internalAuthorized retorna true quando o secret não está definido — inclusive com ENVIRONMENT=production se a variável faltar.
ALTA	apps/workers/realtime-hub/src/index.ts:72-78 + packages/auth/src/session-token.ts:69-72	F03 — WebSocket autoriza branch sem amarrar ao tenant (tid) do JWT canAccessBranch com branches=[] (admins) aceita qualquer branchId UUID. Não há SELECT branches.tenant_id === payload.tid.
ALTA	apps/workers/api-gateway/src/lib/config.ts:17-35 + infra/hetzner/.env.production.example:10-12	F04 — getJwtSecret / getInternalSecret aceitam placeholders CHANGE_ME_* (≥16 chars) Validação só exige comprimento mínimo 16. Strings publicadas no example (CHANGE_ME_openssl_rand_base64_32) passam. Pagamentos já rejeitam placeholders.
MÉDIA	apps/web/src/components/dashboard/DashboardShell.tsx:32-34 + apps/web/src/lib/nav.ts	F05 — Shell/nav só checam token; páginas admin/finance/LGPD sem gate de papel no UI useEffect redireciona só se !getToken(). Nav mostra Tenants/Configurações a qualquer logado. APIs exigem requireRole — UI não.
MÉDIA	apps/workers/api-gateway/src/routes/lgpdt.ts:70-108 (export :89-94)	F06 — LGPD export: qualquer autenticado obtém amostra de pedidos do tenant inteiro handleLgpdExport usa requireAuth sem requireRole. Consents filtrados pelo user; orders filtram só tenant_id + customer_phone IS NOT NULL (até 100).
MÉDIA	apps/workers/api-gateway/src/routes/order-payments.ts:47-94 e :260-296; index.ts:419-439	F07 — Pagamento de pedido público por branchId+orderId (UUID) sem prova de posse POST .../pay e GET .../payment sem requireAuth. Tenant resolvido via branch (bom). Qualquer um com os UUIDs inicia PIX/cartão ou lê status.
MÉDIA	apps/web/src/lib/api.ts (accessToken/refreshToken em localStorage) + login page	F08 — Tokens JWT ainda persistidos em localStorage (além de cookies HttpOnly) storeSession grava access/refresh no localStorage; realtimeWsProtocols lê getToken(). Cookies HttpOnly existem, mas o token permanece acessível a XSS.
MÉDIA	apps/workers/integrations/src/webhooks/mercadopago.ts:91-100	F09 — Webhook Mercado Pago com assinatura opcional Se MERCADOPAGO_WEBHOOK_SECRET ausente, o webhook aceita requests sem assinatura.
BAIXA	apps/workers/api-gateway/src/routes/finance.ts:60-73 e :122-132	F10 — Financeiro: sessão/caixa por tenant sem ACL de filial no JWT Filtra tenant_id corretamente (anti cross-tenant). Papéis finance podem abrir/fechar sessão em qualquer branchId do tenant sem checar user.branches.
BAIXA	docker-compose.yml:8-11 + packages/database/src/index.ts:6-12	F11 — Senha local hardcoded inova_gastro_dev Compose local e fallback de DATABASE_URL embutem senha de desenvolvimento.

Sev.	Local	Descrição
INFORMATIVA	.gitignore vs .github/workflows/ci.yml (secrets-guard)	F12 — .env.production não está no .gitignore (CI bloqueia se tracked) Processo depende do CI secrets-guard; .gitignore raiz não lista .env.production.

5. Detalhamento por categoria (arquivo:linha)

1. Isolamento / banco

F01 [CRÍTICA] Webhook Asaas sem token obrigatório + assinatura de assinatura confia no body

Local: apps/workers/integrations/src/webhooks/asaas.ts:169-174 e :89-120

Explorabilidade: POST forjado com externalReference 'plano' pode ativar/cancelar billing de qualquer tenant. Condição: token de webhook não configurado (ou ambiente com PAYMENTS_ENABLED e token vazio).

Trecho:

```
if (env.ASAAS_WEBHOOK_TOKEN) {
  const valid = verifyAsaasWebhookToken(...);
  if (!valid) return 401;
}
// ...
```

```
const [tenantId, planCode] = ref.split(":");
await callApplySubscription(env, { tenantId, status: mapped, ... });
```

Correção: Em produção, falhar se ASAAS_WEBHOOK_TOKEN ausente; para SUBSCRIPTION_*, buscar a assinatura na API Asaas e só então aplicar status.

F02 [CRÍTICA] messaging-bus libera /internal/publish sem INTERNAL_SHARED_SECRET

Local: apps/workers/messaging-bus/src/index.ts:14-16 e :74-82

Explorabilidade: Quem alcançar a porta/rede do messaging-bus pode publicar eventos forjados para realtime e integrations com branchId arbitrário. Condição: INTERNAL_SHARED_SECRET ausente no container.

Trecho:

```
function internalAuthorized(request, env) {
  if (!env.INTERNAL_SHARED_SECRET) return true; // fail-open
  return request.headers.get("x-internal-secret") === env.INTERNAL_SHARED_SECRET;
}
```

Correção: Fail-closed: sem secret → 403 (espelhar realtime-hub / outbox flush). Obrigar secret ≥16 e rejeitar placeholders CHANGE_ME_*.

3. IDOR

F03 [ALTA] WebSocket autoriza branch sem amarrar ao tenant (tid) do JWT

Local: apps/workers/realtime-hub/src/index.ts:72-78 + packages/auth/src/session-token.ts:69-72

Explorabilidade: Admin/cliente com JWT válido e branches vazio conecta em /ws?branchId= e recebe eventos operacionais ao vivo se o UUID for conhecido.

Trecho:

```
if (!payload || !canAccessBranch(payload, branchId)) return unauthorized();
// canAccessBranch: if (user.branches.length === 0) return true;
```

Correção: Resolver branchId→tenant_id no hub (ou cache) e exigir === payload.tid (mesmo padrão de assertCatalogBranchAccess).

4. Chaves expostas

F04 [ALTA] getJwtSecret / getInternalSecret aceitam placeholders CHANGE_ME_* (≥16 chars)

Local: apps/workers/api-gateway/src/lib/config.ts:17-35 +

infra/hetzner/.env.production.example:10-12

Explorabilidade: Se .env.production for copiado do example sem configure-security-env-vps.sh, atacante conhece JWT_SECRET/INTERNAL e forja tokens / chama rotas internas.

Trecho:

```
if (!secret || secret.length < MIN_SECRET_LENGTH) throw ConfigError(...);
return secret; // não rejeita CHANGE_ME_openssl_rand_base64_32
```

Correção: Rejeitar /CHANGE_ME|change-me/i (como payments-config PLACEHOLDER) e exigir entropia mínima; falhar startup em produção.

2. Permissão no navegador

F05 [MÉDIA] Shell/nav só checam token; páginas admin/finance/LGPD sem gate de papel no UI

Local: apps/web/src/components/dashboard/DashboardShell.tsx:32-34 + apps/web/src/lib/nav.ts

Explorabilidade: Usuário atendente abre /dashboard/admin/tenants e vê formulários; mutações falham 403. Não é bypass de API, mas vazamento de UX e superfície.

Trecho:

```
useEffect(() => {
  if (!isPublic && !getToken()) router.replace("/login");
}, [router, isPublic]);
```

Correção: Carregar /auth/me e ocultar rotas por role; preferir middleware Next. Manter requireRole no servidor como fonte da verdade.

3. IDOR

F06 [MÉDIA] LGPD export: qualquer autenticado obtém amostra de pedidos do tenant inteiro

Local: apps/workers/api-gateway/src/routes/lgpd.ts:70-108 (export :89-94)

Explorabilidade: Qualquer papel autenticado no tenant exporta metadados de pedidos de clientes (número, canal, status, totais). Over-collection / privilégio horizontal no tenant.

Trecho:

```
const orders = await sql`
  SELECT id, order_number, channel, status, total_cents, ...
  FROM orders WHERE tenant_id = ${user.tid}::uuid AND customer_phone IS NOT NULL
  LIMIT 100`;
```

Correção: Restringir a admin_cliente/super_admin e/ou filtrar pedidos ao subject; não incluir amostra operacional sem necessidade LGPD do titular.

F07 [MÉDIA] Pagamento de pedido público por branchId+orderId (UUID) sem prova de posse

Local: apps/workers/api-gateway/src/routes/order-payments.ts:47-94 e :260-296; index.ts:419-439

Explorabilidade: IDOR residual de checkout convidado: enumeração/uso de UUIDs vazados. Design intencional parcial — risco se IDs vazarem em logs/referrer.

Trecho:

```
// index.ts: sem requireAuth
await handlePayOrder(request, env, branchId, orderId);
```

Correção: Token de convidado assinado no create-order (HMAC curto) exigido no pay/status.

4. Chaves expostas

F08 [MÉDIA] Tokens JWT ainda persistidos em localStorage (além de cookies HttpOnly)

Local: apps/web/src/lib/api.ts (accessToken/refreshToken em localStorage) + login page

Explorabilidade: Qualquer XSS no domínio exfiltra access+refresh. Condição: vulnerabilidade XSS (hoje não há dangerouslySetInnerHTML encontrado).

Trecho:

```
localStorage.setItem("accessToken", accessToken);
if (refreshToken) localStorage.setItem("refreshToken", refreshToken);
```

Correção: Concluir migração cookie-only; WS same-site via cookie; token de uso único curto só se cross-origin.

1. Isolamento / banco

F09 [MÉDIA] Webhook Mercado Pago com assinatura opcional

Local: apps/workers/integrations/src/webhooks/mercadopago.ts:91-100

Explorabilidade: Forçar processamento de notificações para payment IDs conhecidos. Condição: secret não configurado (legado MP ainda no código).

Trecho:

```
if (env.MERCADOPAGO_WEBHOOK_SECRET) {
  const valid = verifyMercadoPagoSignature(...);
  if (!valid) return 401;
}
```

Correção: Fail-closed em produção; ou desativar rota MP se ORDER_PAYMENT_PROVIDER=asaas.

3. IDOR

F10 [BAIXA] Financeiro: sessão/caixa por tenant sem ACL de filial no JWT

Local: apps/workers/api-gateway/src/routes/finance.ts:60-73 e :122-132

Explorabilidade: Privilégio lateral entre filiais do mesmo tenant (gerente de A opera caixa de B).

Trecho:

```
WHERE id = ${sessionId}::uuid AND tenant_id = ${user.tid}::uuid AND status = 'open'
```

Correção: Reusar assertBranchOpsAccess / membership antes de open/close/sangria.

4. Chaves expostas

F11 [BAIXA] Senha local hardcoded inova_gastro_dev

Local: docker-compose.yml:8-11 + packages/database/src/index.ts:6-12

Explorabilidade: Baixo: bind 127.0.0.1; risco em máquina compartilhada com Docker.

Trecho:

```
POSTGRES_PASSWORD: inova_gastro_dev
```

```
# packages/database: postgresql://inova_gastro:inova_gastro_dev@127.0.0.1:5440/...
```

Correção: Usar env POSTGRES_PASSWORD também no compose local; remover fallback com senha.

F12 [INFORMATIVA] .env.production não está no .gitignore (CI bloqueia se tracked)

Local: .gitignore vs .github/workflows/ci.yml (secrets-guard)

Explorabilidade: Risco operacional de commit acidental se CI for pulado.

Trecho:

```
CI: if git ls-files | grep '.env.production' → fail
```

Correção: Adicionar .env.production ao .gitignore na raiz.

6. Recomendações priorizadas

P1. Fail-closed em webhooks Asaas/MP e messaging-bus sem secret; revalidar SUBSCRIPTION_* na API Asaas.

P2. Amarração branchId→tenant_id no realtime WS; rejeitar placeholders JWT/INTERNAL no startup (como payments-config).

P3. Restringir LGPD export a admins/subject; ACL de filial no finance; ocultar nav admin por role; concluir cookie-only tokens.

P4. Adicionar .env.production ao .gitignore; token de convidado para pay/status; remover senha hardcoded do compose local/fallback Prisma.

7. Cobertura — o que foi verificado e está correto

Handlers settings (company/branches/users), admin-tenants, catalog-admin (assertCatalogBranchAccess), orders list/get/status e print-jobs (assertBranchOpsAccess), finance listagens com tenant_id, LGPD erasure com role, billing mutate com role, internal outbox flush fail-closed, Stripe webhook com constructEvent, upload multipart com magic bytes, ausência de dangerouslySetInnerHTML, sanitização de image_url http(s).

8. ISSUES PARA O GITHUB

Copie cada bloco entre os delimitadores para abrir uma issue. Achados locais (compose + fallback DB) foram agrupados na issue F11.

```

--- ISSUE F01 ---
# [Segurança] Webhook Asaas sem token obrigatório + assinatura de assinatura confia no body

**Labels sugeridas:** `security`, `severity:crítica`

## Problema
Se ASAAS_WEBHOOK_TOKEN estiver ausente, a verificação é pulada. Eventos SUBSCRIPTION_* mapeiam tenantId/
status a partir do JSON do atacante e chamam apply-subscription sem revalidar na API Asaas.

## Por que é explorável
POST forjado com externalReference '<uuid-vitima>:plano' pode ativar/cancelar billing de qualquer tenant.
Condição: token de webhook não configurado (ou ambiente com PAYMENTS_ENABLED e token vazio).

## Evidência
`apps/workers/integrations/src/webhooks/asaas.ts:169-174 e :89-120`
...
if (env.ASAAS_WEBHOOK_TOKEN) {
  const valid = verifyAsaasWebhookToken(...);
  if (!valid) return 401;
}
// ...
const [tenantId, planCode] = ref.split(":");
await callApplySubscription(env, { tenantId, status: mapped, ... });
...

## Impacto
Severidade **crítica** – categoria 1. Isolamento / banco.

## Sugestão de correção
Em produção, falhar se ASAAS_WEBHOOK_TOKEN ausente; para SUBSCRIPTION_*, buscar a assinatura na API Asaas e
só então aplicar status.

## Critérios de aceite
- [ ] Correção aplicada e coberta por teste automatizado (reprodução do cenário falha com 401/403)
- [ ] Não é possível explorar o fluxo descrito com o pré-requisito de configuração documentado
- [ ] Code review / CI verdes no pacote afetado
--- FIM ISSUE F01 ---

--- ISSUE F02 ---
# [Segurança] messaging-bus libera /internal/publish sem INTERNAL_SHARED_SECRET

**Labels sugeridas:** `security`, `severity:crítica`

## Problema
internalAuthorized retorna true quando o secret não está definido – inclusive com ENVIRONMENT=production se a
variável faltar.

## Por que é explorável
Quem alcançar a porta/rede do messaging-bus pode publicar eventos forjados para realtime e integrations com
branchId arbitrário. Condição: INTERNAL_SHARED_SECRET ausente no container.

## Evidência
`apps/workers/messaging-bus/src/index.ts:14-16 e :74-82`
...
function internalAuthorized(request, env) {
  if (!env.INTERNAL_SHARED_SECRET) return true; // fail-open
  return request.headers.get("x-internal-secret") === env.INTERNAL_SHARED_SECRET;
}
...

## Impacto
Severidade **crítica** – categoria 1. Isolamento / banco.
## Sugestão de correção

```

Fail-closed: sem secret → 403 (espelhar realtime-hub / outbox flush). Obrigar secret ≥16 e rejeitar placeholders CHANGE_ME_*.

Critérios de aceite

- [] Correção aplicada e coberta por teste automatizado (reprodução do cenário falha com 401/403)
 - [] Não é possível explorar o fluxo descrito com o pré-requisito de configuração documentado
 - [] Code review / CI verdes no pacote afetado
- FIM ISSUE F02 ---

--- ISSUE F03 ---

[Segurança] WebSocket autoriza branch sem amarrar ao tenant (tid) do JWT

Labels sugeridas: `security`, `severity:alta`

Problema

canAccessBranch com branches=[] (admins) aceita qualquer branchId UUID. Não há SELECT branches.tenant_id == payload.tid.

Por que é explorável

Admin/cliente com JWT válido e branches vazio conecta em /ws?branchId=<uuid de outro tenant> e recebe eventos operacionais ao vivo se o UUID for conhecido.

Evidência

`apps/workers/realtime-hub/src/index.ts:72-78 + packages/auth/src/session-token.ts:69-72`

...

```
if (!payload || !canAccessBranch(payload, branchId)) return unauthorized();
// canAccessBranch: if (user.branches.length === 0) return true;
```

...

Impacto

Severidade **alta** – categoria 3. IDOR.

Sugestão de correção

Resolver branchId→tenant_id no hub (ou cache) e exigir == payload.tid (mesmo padrão de assertCatalogBranchAccess).

Critérios de aceite

- [] Correção aplicada e coberta por teste automatizado (reprodução do cenário falha com 401/403)
 - [] Não é possível explorar o fluxo descrito com o pré-requisito de configuração documentado
 - [] Code review / CI verdes no pacote afetado
- FIM ISSUE F03 ---

--- ISSUE F04 ---

[Segurança] getJwtSecret / getInternalSecret aceitam placeholders CHANGE_ME_* (≥16 chars)

Labels sugeridas: `security`, `severity:alta`

Problema

Validação só exige comprimento mínimo 16. Strings publicadas no example (CHANGE_ME_openssl_rand_base64_32) passam. Pagamentos já rejeitam placeholders.

Por que é explorável

Se .env.production for copiado do example sem configure-security-env-vps.sh, atacante conhece JWT_SECRET/INTERNAL e forja tokens / chama rotas internas.

Evidência

`apps/workers/api-gateway/src/lib/config.ts:17-35 + infra/hetzner/.env.production.example:10-12`

...

```
if (!secret || secret.length < MIN_SECRET_LENGTH) throw ConfigError(...);
return secret; // não rejeita CHANGE_ME_openssl_rand_base64_32
```

...

Impacto

Severidade **alta** – categoria 4. Chaves expostas.

Sugestão de correção

Rejeitar /CHANGE_ME|change-me/i (como payments-config PLACEHOLDER) e exigir entropia mínima; falhar startup em produção.

Critérios de aceite

```

- [ ] Correção aplicada e coberta por teste automatizado (reprodução do cenário falha com 401/403)
- [ ] Não é possível explorar o fluxo descrito com o pré-requisito de configuração documentado
- [ ] Code review / CI verdes no pacote afetado
--- FIM ISSUE F04 ---

--- ISSUE F05 ---
# [Segurança] Shell/nav só checam token; páginas admin/finance/LGPD sem gate de papel no UI

**Labels sugeridas:** `security`, `severity:média`

## Problema
useEffect redireciona só se !getToken(). Nav mostra Tenants/Configurações a qualquer logado. APIs exigem
requireRole – UI não.

## Por que é explorável
Usuário atendente abre /dashboard/admin/tenants e vê formulários; mutações falham 403. Não é bypass de API,
mas vazamento de UX e superfície.

## Evidência
`apps/web/src/components/dashboard/DashboardShell.tsx:32-34 + apps/web/src/lib/nav.ts`
...
useEffect(() => {
  if (!isPublic && !getToken()) router.replace("/login");
}, [router, isPublic]);
...

## Impacto
Severidade **média** – categoria 2. Permissão no navegador.

## Sugestão de correção
Carregar /auth/me e ocultar rotas por role; preferir middleware Next. Manter requireRole no servidor como
fonte da verdade.

## Critérios de aceite
- [ ] Correção aplicada e coberta por teste automatizado (reprodução do cenário falha com 401/403)
- [ ] Não é possível explorar o fluxo descrito com o pré-requisito de configuração documentado
- [ ] Code review / CI verdes no pacote afetado
--- FIM ISSUE F05 ---

--- ISSUE F06 ---
# [Segurança] LGPD export: qualquer autenticado obtém amostra de pedidos do tenant inteiro

**Labels sugeridas:** `security`, `severity:média`

## Problema
handleLgpdExport usa requireAuth sem requireRole. Consents filtrados pelo user; orders filtram só tenant_id +
customer_phone IS NOT NULL (até 100).

## Por que é explorável
Qualquer papel autenticado no tenant exporta metadados de pedidos de clientes (número, canal, status, totais).
Over-collection / privilégio horizontal no tenant.

## Evidência
`apps/workers/api-gateway/src/routes/lgpd.ts:70-108 (export :89-94)`
...
const orders = await sql`
  SELECT id, order_number, channel, status, total_cents, ...
  FROM orders WHERE tenant_id = ${user.tid}::uuid AND customer_phone IS NOT NULL
  LIMIT 100`;
...

## Impacto
Severidade **média** – categoria 3. IDOR.

## Sugestão de correção
Restringir a admin_cliente/super_admin e/ou filtrar pedidos ao subject; não incluir amostra operacional sem
necessidade LGPD do titular.

## Critérios de aceite

```

```

- [ ] Correção aplicada e coberta por teste automatizado (reprodução do cenário falha com 401/403)
- [ ] Não é possível explorar o fluxo descrito com o pré-requisito de configuração documentado
- [ ] Code review / CI verdes no pacote afetado
--- FIM ISSUE F06 ---

--- ISSUE F07 ---
# [Segurança] Pagamento de pedido público por branchId+orderId (UUID) sem prova de posse

**Labels sugeridas:** `security`, `severity:média`

## Problema
POST .../pay e GET .../payment sem requireAuth. Tenant resolvido via branch (bom). Qualquer um com os UUIDs
inicia PIX/cartão ou lê status.

## Por que é explorável
IDOR residual de checkout convidado: enumeração/uso de UUIDs vazados. Design intencional parcial – risco se
IDs vazarem em logs/referrer.

## Evidência
`apps/workers/api-gateway/src/routes/order-payments.ts:47-94 e :260-296; index.ts:419-439`
...
// index.ts: sem requireAuth
await handlePayOrder(request, env, branchId, orderId);
...

## Impacto
Severidade **média** – categoria 3. IDOR.

## Sugestão de correção
Token de convidado assinado no create-order (HMAC curto) exigido no pay/status.

## Critérios de aceite
- [ ] Correção aplicada e coberta por teste automatizado (reprodução do cenário falha com 401/403)
- [ ] Não é possível explorar o fluxo descrito com o pré-requisito de configuração documentado
- [ ] Code review / CI verdes no pacote afetado
--- FIM ISSUE F07 ---

--- ISSUE F08 ---
# [Segurança] Tokens JWT ainda persistidos em localStorage (além de cookies HttpOnly)

**Labels sugeridas:** `security`, `severity:média`

## Problema
storeSession grava access/refresh no localStorage; realtimeWSProtocols lê getToken(). Cookies HttpOnly
existem, mas o token permanece acessível a XSS.

## Por que é explorável
Qualquer XSS no domínio exfiltra access+refresh. Condição: vulnerabilidade XSS (hoje não há
dangerouslySetInnerHTML encontrado).

## Evidência
`apps/web/src/lib/api.ts (accessToken/refreshToken em localStorage) + login page`
...
localStorage.setItem("accessToken", accessToken);
if (refreshToken) localStorage.setItem("refreshToken", refreshToken);
...

## Impacto
Severidade **média** – categoria 4. Chaves expostas.

## Sugestão de correção
Concluir migração cookie-only; WS same-site via cookie; token de uso único curto só se cross-origin.

## Critérios de aceite
- [ ] Correção aplicada e coberta por teste automatizado (reprodução do cenário falha com 401/403)
- [ ] Não é possível explorar o fluxo descrito com o pré-requisito de configuração documentado
- [ ] Code review / CI verdes no pacote afetado
--- FIM ISSUE F08 ---

```

--- ISSUE F09 ---

[Segurança] Webhook Mercado Pago com assinatura opcional

Labels sugeridas: `security`, `severity:média`

Problema

Se MERCADOPAGO_WEBHOOK_SECRET ausente, o webhook aceita requests sem assinatura.

Por que é explorável

Forçar processamento de notificações para payment IDs conhecidos. Condição: secret não configurado (legado MP ainda no código).

Evidência

`apps/workers/integrations/src/webhooks/mercadopago.ts:91-100`

...

```
if (env.MERCADOPAGO_WEBHOOK_SECRET) {
  const valid = verifyMercadoPagoSignature(...);
  if (!valid) return 401;
}
```

...

Impacto

Severidade **média** – categoria 1. Isolamento / banco.

Sugestão de correção

Fail-closed em produção; ou desativar rota MP se ORDER_PAYMENT_PROVIDER=asaas.

Critérios de aceite

- [] Correção aplicada e coberta por teste automatizado (reprodução do cenário falha com 401/403)
- [] Não é possível explorar o fluxo descrito com o pré-requisito de configuração documentado
- [] Code review / CI verdes no pacote afetado

--- FIM ISSUE F09 ---

--- ISSUE F10 ---

[Segurança] Financeiro: sessão/caixa por tenant sem ACL de filial no JWT

Labels sugeridas: `security`, `severity:baixa`

Problema

Filtra tenant_id corretamente (anti cross-tenant). Papéis finance podem abrir/fechar sessão em qualquer branchId do tenant sem checar user.branches.

Por que é explorável

Privilegio lateral entre filiais do mesmo tenant (gerente de A opera caixa de B).

Evidência

`apps/workers/api-gateway/src/routes/finance.ts:60-73 e :122-132`

...

WHERE id = \${sessionId}::uuid AND tenant_id = \${user.tid}::uuid AND status = 'open'

...

Impacto

Severidade **baixa** – categoria 3. IDOR.

Sugestão de correção

Reusar assertBranchOpsAccess / membership antes de open/close/sangria.

Critérios de aceite

- [] Correção aplicada e coberta por teste automatizado (reprodução do cenário falha com 401/403)
- [] Não é possível explorar o fluxo descrito com o pré-requisito de configuração documentado
- [] Code review / CI verdes no pacote afetado

--- FIM ISSUE F10 ---

--- ISSUE F11 ---

[Segurança] Senha local hardcoded inova_gastro_dev

Labels sugeridas: `security`, `severity:baixa`

Problema

```

Compose local e fallback de DATABASE_URL embutem senha de desenvolvimento.

## Por que é explorável
Baixo: bind 127.0.0.1; risco em máquina compartilhada com Docker.

## Evidência
`docker-compose.yml:8-11 + packages/database/src/index.ts:6-12`
...
POSTGRES_PASSWORD: inova_gastro_dev
# packages/database: postgresql://inova_gastro:inova_gastro_dev@127.0.0.1:5440/...
...

## Impacto
Severidade **baixa** – categoria 4. Chaves expostas.

## Sugestão de correção
Usar env POSTGRES_PASSWORD também no compose local; remover fallback com senha.

## Critérios de aceite
- [ ] Correção aplicada e coberta por teste automatizado (reprodução do cenário falha com 401/403)
- [ ] Não é possível explorar o fluxo descrito com o pré-requisito de configuração documentado
- [ ] Code review / CI verdes no pacote afetado
--- FIM ISSUE F11 ---

--- ISSUE F12 ---
# [Segurança] .env.production não está no .gitignore (CI bloqueia se tracked)

**Labels sugeridas:** `security`, `severity:informativa`

## Problema
Processo depende do CI secrets-guard; .gitignore raiz não lista .env.production.

## Por que é explorável
Risco operacional de commit acidental se CI for pulado.

## Evidência
`.gitignore vs .github/workflows/ci.yml (secrets-guard)`
...
CI: if git ls-files | grep '.env.production' → fail
...

## Impacto
Severidade **informativa** – categoria 4. Chaves expostas.

## Sugestão de correção
Adicionar .env.production ao .gitignore na raiz.

## Critérios de aceite
- [ ] Correção aplicada e coberta por teste automatizado (reprodução do cenário falha com 401/403)
- [ ] Não é possível explorar o fluxo descrito com o pré-requisito de configuração documentado
- [ ] Code review / CI verdes no pacote afetado
--- FIM ISSUE F12 ---

```